Replace and modernize legacy VPN architectures with a cloud-native ZscalerZero Trust solution to reduce attack surface and lateral movement

S.No	NAME	COLLEGE NAME	CONTACT
1.	DIVYA T	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bsca124divyat@skacas.ac.in
2.	DEVADHARSHINI M	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bsca118devadharshinim@skacas.ac.in
3.	BUVANASRI K	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bsca116buvanasrik@skacas.ac.in
4.	CHARUHASINI P	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bsca117charuhasinip@skacas.ac.in

Project details

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats..

Abstract:

This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce.

The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloudnative platform that shifts connectivity from a network-centric to an identity and application-centric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler’s edge nodes, optimizing the user experience regardless of their location.

The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, highperformance, and agile work environment, future-proofing the organization's security architecture.

Use Case Scenarios:

Scenario 1: Third-Party Vendor Access to Finance Application

An external auditor needs temporary access to the university's finance application for end-ofyear reconciliation. Instead of provisioning a VPN account, ZPA grants time-bound, applicationspecific access. The vendor authenticates via identity provider and is micro-segmented away from all other internal resources.

Output:

- User identity verified (External_Auditor_Group)
- Time-bound access policy enforced (7-day validity)
- Connection restricted to Finance Application only
- No lateral movement possible to other systems

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

A graduate student requires SSH access to an on-premises research computing cluster to run data analysis scripts. Using ZPA, they connect directly to the cluster without exposing SSH ports to the internet or requiring a full network-level VPN tunnel.

Output:

- User identity verified (Research_Assistant_Group)
- Protocol-specific access granted (SSH only)
- Direct micro-tunnel established to HPC Cluster
- All other network segments remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

An administrative assistant working from a campus satellite office needs to access a sensitive file server containing student records. ZPA verifies their device compliance and routes them exclusively to the file server application, with all traffic inspected inline for data loss prevention.

Output:

- User identity verified (Admin_Staff_Group)

Device posture compliant (Disk encryption enabled, patch level current)

Output:

- Student identities verified through institutional login system
- Secure access granted only to LMS application
- Access to administrative systems and internal servers blocked
- LMS server IP address hidden from public internet exposure

Scenario 4: IT Administrator Accessing Server Management Interface

An IT administrator needs to perform maintenance on an internal application server. Instead of receiving full network access through a VPN, the administrator uses ZTNA-based secure access to connect only to the server management interface. The session is monitored continuously to ensure compliance with security policies.

Output:

- Administrator identity verified using MFA authentication
- Secure micro-tunnel created to Server Management Interface only
- Administrative actions logged for auditing and compliance
- Attempts to access unauthorized servers automatically blocked

Scenario 5: Temporary Vendor Access to Internal Application

A third-party vendor hired for system maintenance requires temporary access to a specific internal application. Using Zscaler ZTNA, the organization creates a time-limited application access policy that allows the vendor to access only the required application without exposing the internal network.

Output:

- Vendor identity verified through temporary credentials
- Access restricted to Maintenance Application only
- All activities logged in the security monitoring system
- Access automatically revoked after project completion

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview: -

- This project is a strategic initiative to fundamentally transform the organization's remote access and network security architecture by decommissioning the existing legacy Virtual Private Network (VPN) infrastructure and replacing it with a cloud-native Zero Trust solution from Zscaler. The current VPN model, based on a perimeter-centric "castle-and-moat" approach, inherently trusts users once they are connected, granting them broad access to the internal network. This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach.
- The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses.

- When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

- The anticipated outcomes of this modernization are profound and multi-faceted. The organization will achieve a drastically reduced attack surface and a complete eradication of lateral movement risks, significantly strengthening its security posture against advanced cyber threats. Operationally, the shift to a cloud-native, globally distributed edge removes the need for traffic hair-pinning, thereby optimizing performance and user experience for a hybrid workforce. This transition also simplifies IT operations by replacing complex, hardware-dependent VPN infrastructure with a unified, scalable, and agile cloud management console. Ultimately, this project will not only fortify the organization's defenses but also create a secure, high-performance, and future-ready access framework that supports evolving business needs.

- This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network."
- By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

List of Vulnerability Table:

S.no	Vulnerability Name	CWE - No
1	Improper Ownership Management	CWE-282
2	Clear text Storage of Sensitive Information in a Cookie	CWE-315
3	Use of Unmaintained Third Party Components	CWE-1104
4	Insufficient Entropy	CWE-331
5	Unchecked Error Condition	CWE-391
6	Embedded Malicious Code	CWE-506
7	Missing Encryption of Sensitive Data	CWE-311
8	Missing XML Validation	CWE-112
9	Missing Critical Step in Authentication	CWE-304
10	Insufficient Logging	CWE-778

REPORT: -

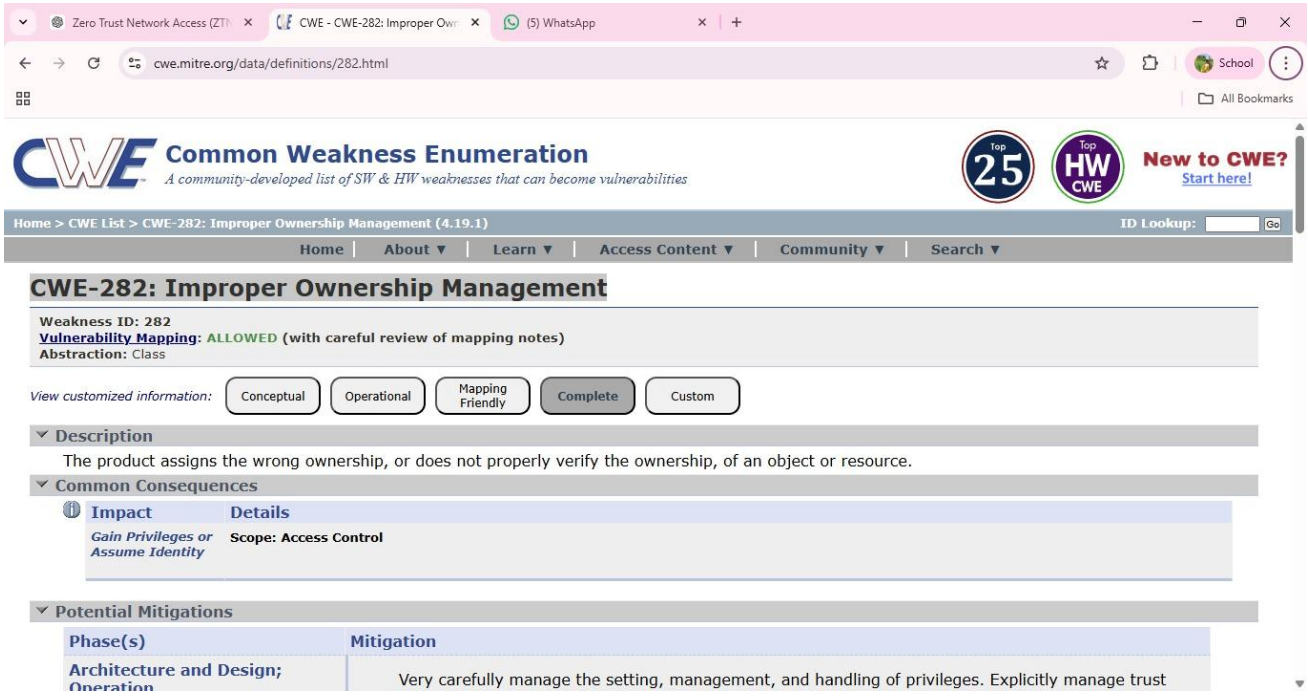
1) Vulnerability Name: Improper Ownership Management

CWE/CVE: CWE-282

OWASP/SANS Category: A01:2025-Broken Access Control

Description: Improper Ownership Management occurs when a system fails to correctly assign or enforce ownership permissions for resources such as files, applications, or data. In such situations, unauthorized users may gain the ability to access, modify, or delete resources that should be restricted to specific owners or administrators. This vulnerability often arises due to incorrect configuration of access controls, weak permission management, or improper handling of user roles and privileges. Attackers may exploit this weakness to manipulate ownership settings, leading to unauthorized control over critical system resources.

Business Impact: If ownership management is not properly enforced, attackers or unauthorized users may gain access to sensitive resources and perform actions that compromise system integrity. This can result in unauthorized modification or deletion of important data, disruption of business operations, and potential data breaches. Additionally, organizations may face financial losses, legal consequences, and reputational damage if sensitive information or critical systems are compromised due to improper access control mechanisms.



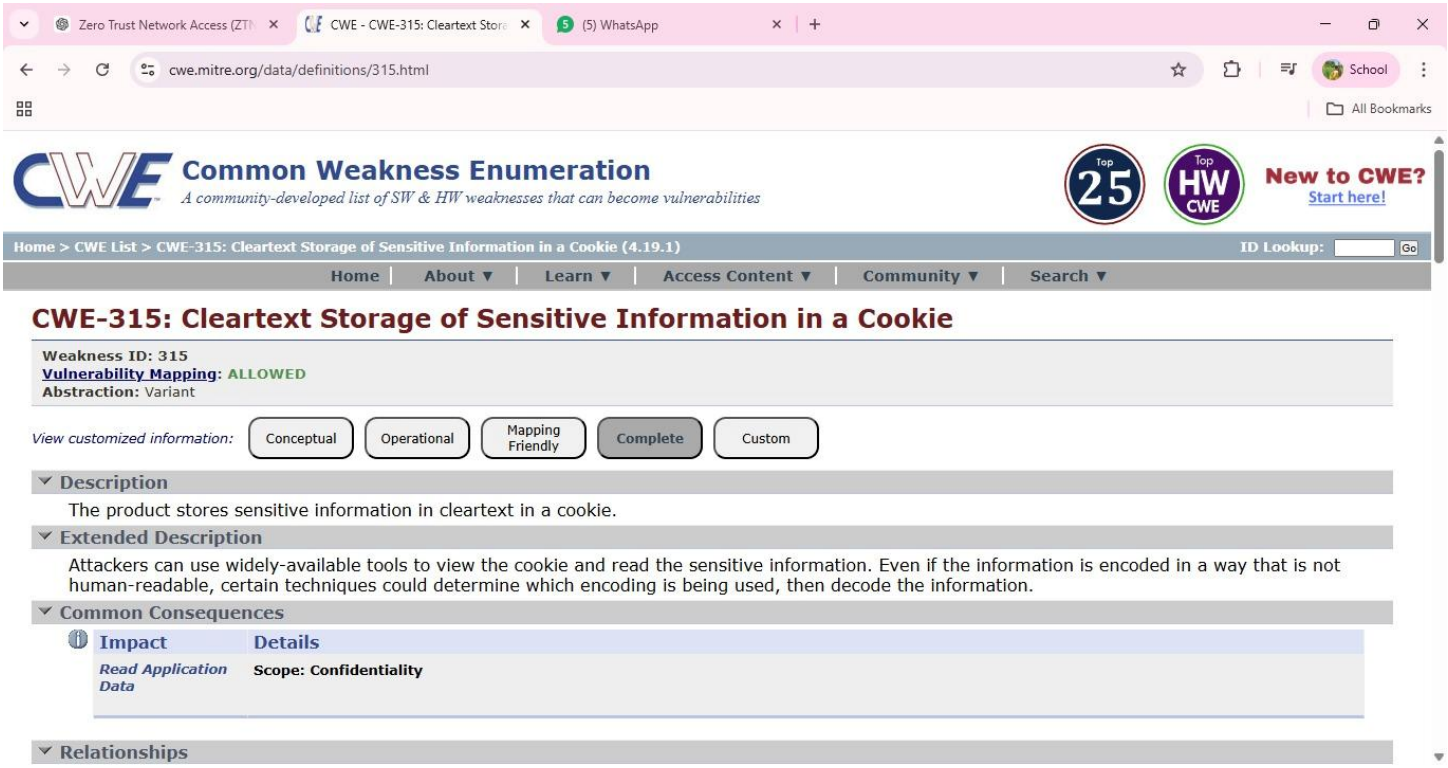
2) Vulnerability Name: **Cleartext Storage of Sensitive Information in a Cookie**

CWE/CVE: CWE-315

OWASP/SANS Category: A02:2025-Security Misconfiguration

Description: Cleartext Storage of Sensitive Information in a Cookie occurs when an application stores confidential data such as user credentials, session identifiers, or personal information in browser cookies without encryption. Since cookies are stored on the client side, they can be accessed by attackers through browser vulnerabilities, cross-site scripting (XSS) attacks, or by intercepting network traffic. If sensitive information is stored in plain text, attackers can easily read and misuse the data to gain unauthorized access to user accounts or application resources.

Business Impact: Storing sensitive information in cleartext cookies can lead to serious security risks such as session hijacking, unauthorized account access, and data breaches. Attackers may impersonate legitimate users and gain access to confidential information or internal systems. This can result in financial loss, legal liabilities, and damage to the organization's reputation, especially if customer or employee data is exposed.



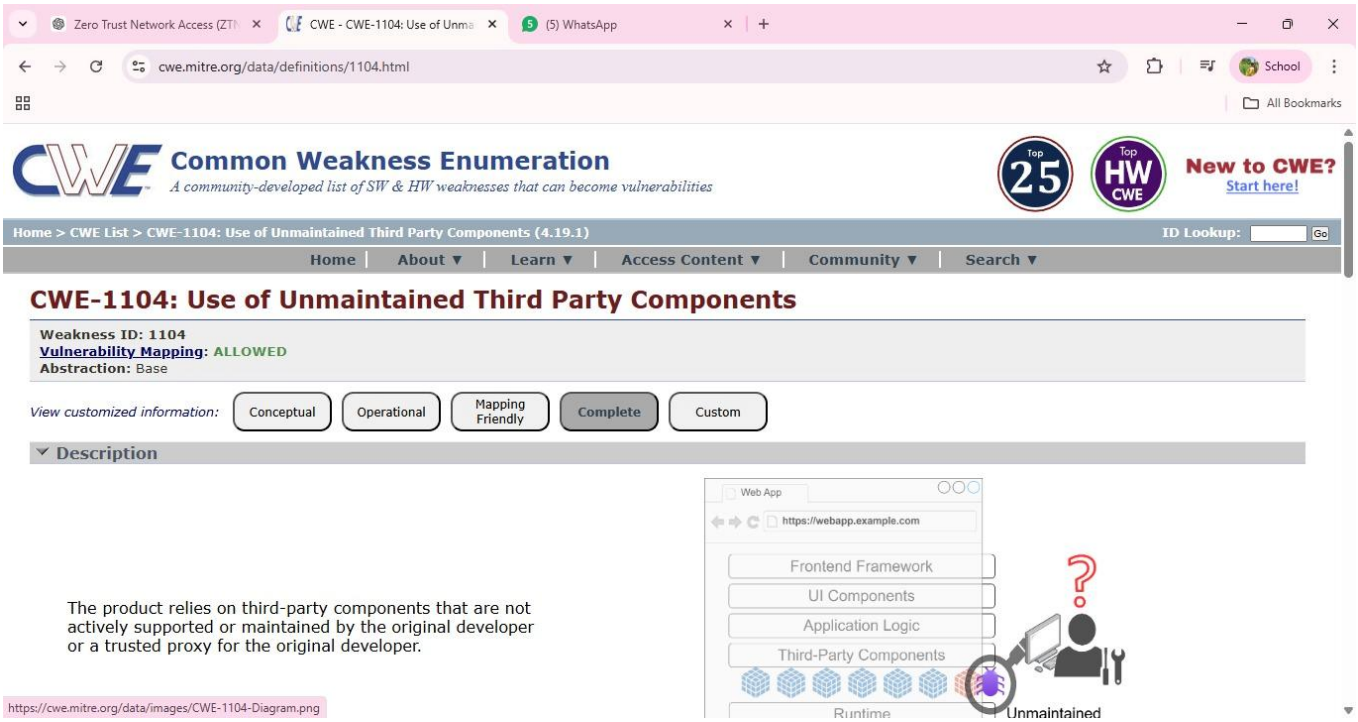
3) Vulnerability Name: **Use of Unmaintained Third Party Components**

CWE/CVE: CWE-1104

OWASP/SANS Category: A03 :2025-Software Supply Chain Failures

Description: Use of Unmaintained Third Party Components occurs when an application depends on external libraries, frameworks, or software components that are no longer actively maintained or updated by their developers. These outdated components may contain known security vulnerabilities that remain unpatched, making the application susceptible to exploitation. Attackers often scan systems for such components and exploit their weaknesses to gain unauthorized access, execute malicious code, or compromise the system.

Business Impact: Using unmaintained third-party components can expose an organization to significant security risks. Attackers may exploit known vulnerabilities to compromise applications, leading to data breaches, service disruptions, or unauthorized system access. This can result in financial losses, regulatory compliance issues, and damage to the organization's reputation. Maintaining updated and supported software components is therefore essential for ensuring long-term system security.



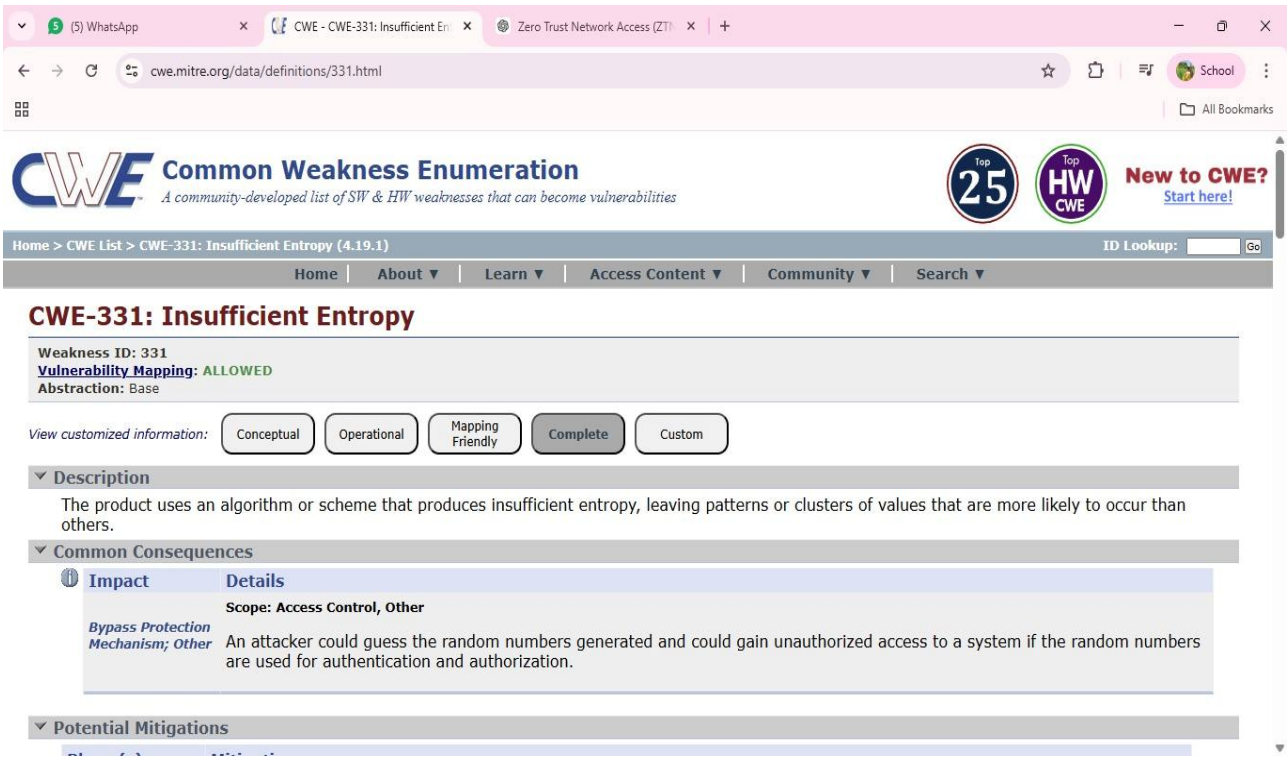
4) Vulnerability Name: **Insufficient Entropy**

CWE/CVE: CWE-331

OWASP/SANS Category: A04 :2025-Cryptographic Failures

Description: Insufficient Entropy occurs when a system generates random values, such as cryptographic keys, session IDs, or tokens, using weak or predictable sources of randomness. Entropy refers to the level of unpredictability in generated values. When entropy is insufficient, attackers may be able to predict or reproduce these values, allowing them to bypass security mechanisms. This vulnerability often appears in authentication systems, encryption processes, or session management where strong randomness is required to maintain security.

Business Impact: If attackers can predict security tokens, session identifiers, or cryptographic keys, they may gain unauthorized access to user accounts or sensitive systems.This can lead to session hijacking, data breaches, and unauthorized transactions. For organizations, such incidents may result in financial losses, legal consequences, and damage to customer trust and reputation. Ensuring strong random number generation is essential to maintain system security.



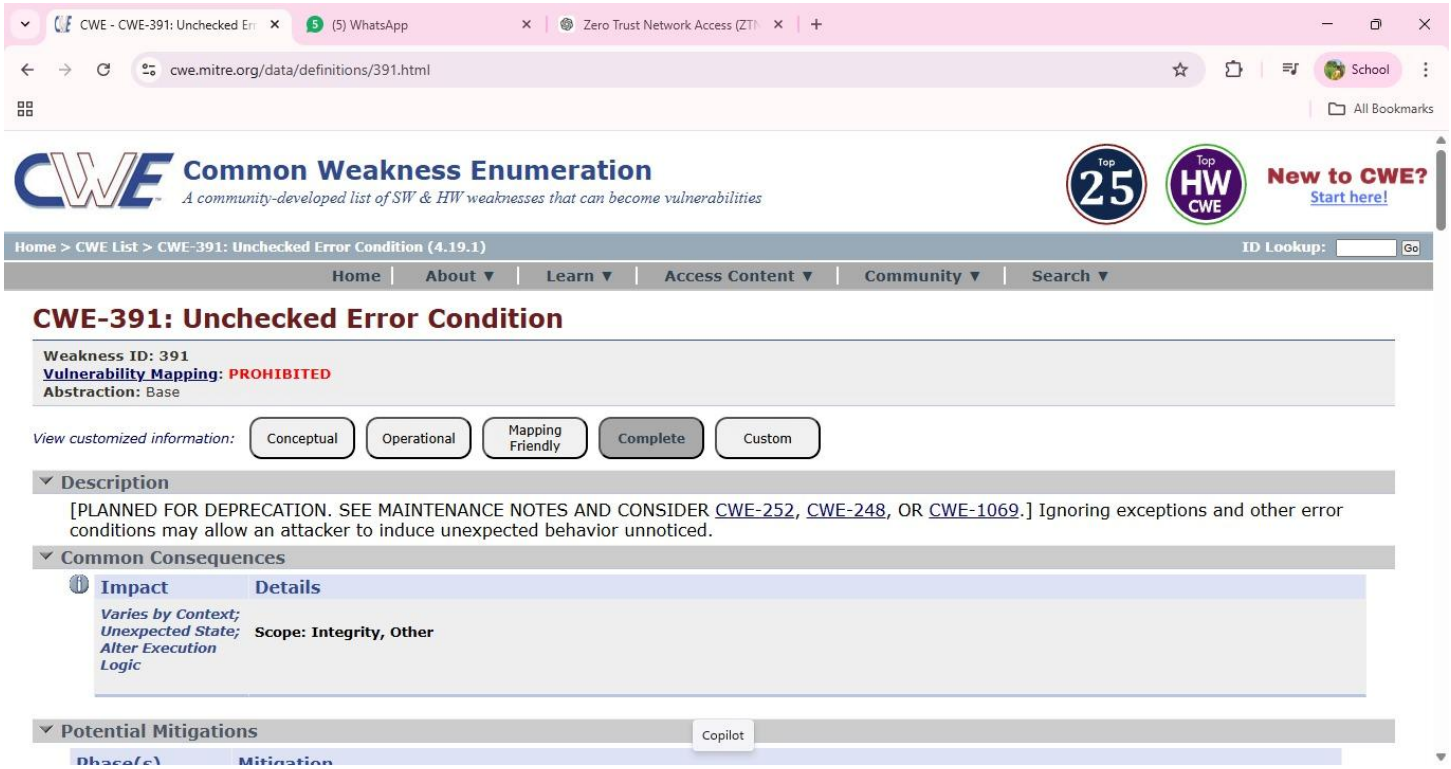
5) Vulnerability Name: **Unchecked Error Condition**

CWE/CVE: CWE-391

OWASP/SANS Category: A10 :2025-Mishandling of Exceptional Conditions

Description: Unchecked Error Condition occurs when a system or application fails to properly handle errors that occur during program execution. Instead of detecting and responding to these errors appropriately, the system may ignore them or continue processing without taking corrective action. This can lead to unexpected system behavior, incorrect outputs, or security weaknesses. Attackers may exploit such situations to trigger abnormal conditions, potentially bypassing security controls or causing the application to behave in unintended ways.

Business Impact: Failure to properly handle errors can result in system instability, data corruption, or unauthorized system behavior. Attackers may exploit these weaknesses to disrupt services, manipulate application functionality, or gain access to sensitive information. For organizations, this can lead to operational downtime, financial losses, and damage to reputation due to unreliable or insecure systems. Proper error handling and monitoring mechanisms are essential to maintain application reliability and security.



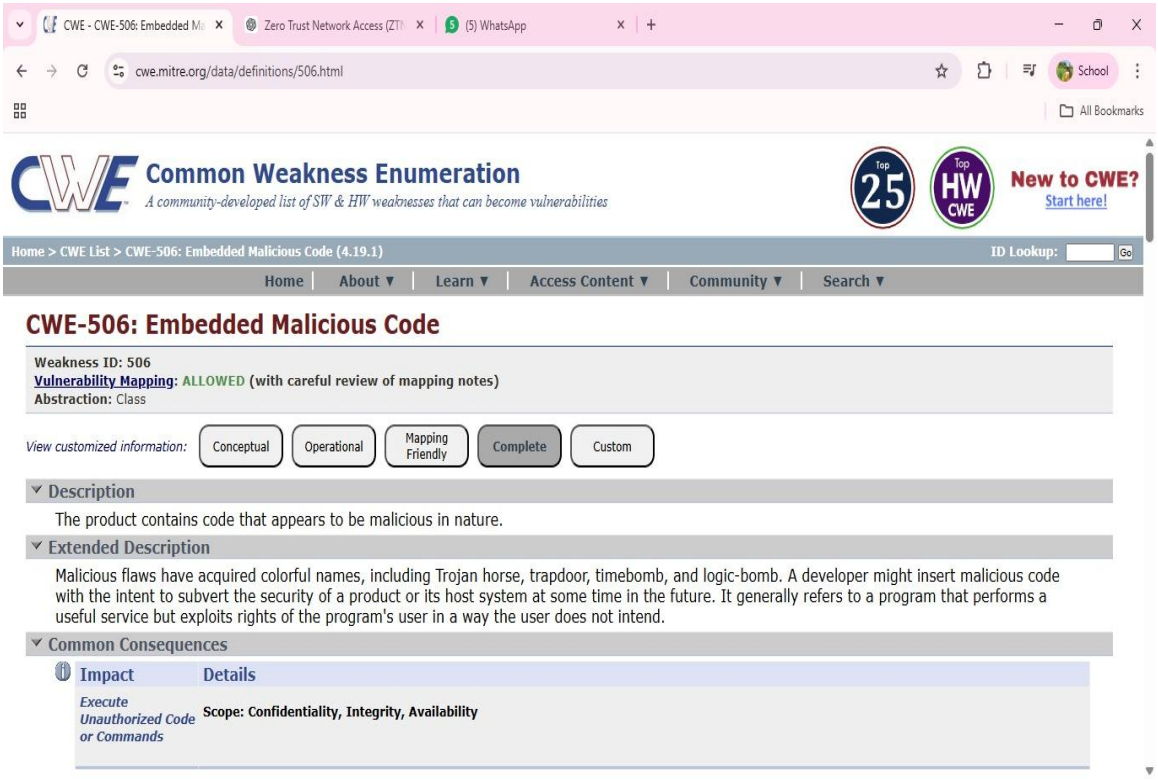
6) Vulnerability Name: **Embedded Malicious Code**

CWE/CVE: CWE-506

OWASP/SANS Category: A08 :2025-Software or Data Integrity Failures

Description: Embedded Malicious Code refers to the presence of intentionally harmful code hidden within an application or software component. This malicious code may be inserted by attackers, compromised third-party libraries, or during insecure development practices. Such code can perform unauthorized actions such as stealing sensitive information, creating backdoors, or executing harmful operations without the user's knowledge. Because the code is embedded within legitimate software, it may remain undetected for long periods and can be triggered under specific conditions.

Business Impact: The presence of embedded malicious code can severely compromise the security and reliability of an organization's systems.Attackers may use it to steal confidential data, gain unauthorized access, or disrupt system operations. This can lead to data breaches, financial losses, operational downtime, and reputational damage. In critical environments, malicious code may also affect the integrity of applications and undermine trust in the organization's software systems.



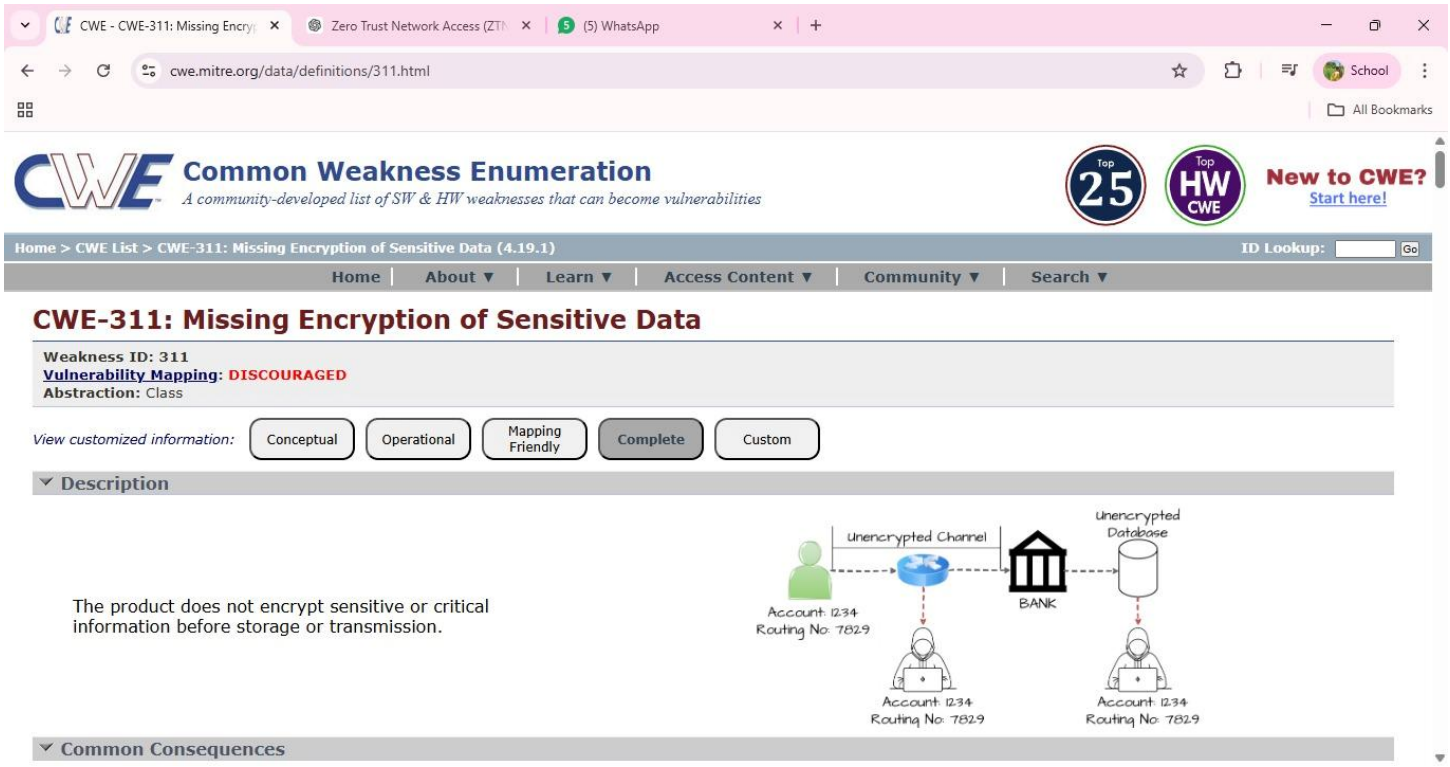
7) **Vulnerability Name:** **Missing Encryption of Sensitive Data**

CWE/CVE: CWE-311

OWASP/SANS Category: A06 :2025-Insecure Design

Description: Missing Encryption of Sensitive Data occurs when an application or system transmits or stores confidential information without using proper encryption mechanisms. Sensitive data such as user credentials, financial records, personal information, or internal system details may be exposed in plain text. If this data is intercepted during transmission or accessed by unauthorized users, attackers can easily read and misuse the information. This vulnerability often arises due to poor security configuration or failure to implement secure communication protocols.

Business Impact: Missing Encryption of Sensitive Data occurs when an application or system transmits or stores confidential information without using proper encryption mechanisms. Sensitive data such as user credentials, financial records, personal information, or internal system details may be exposed in plain text. If this data is intercepted during transmission or accessed by unauthorized users, attackers can easily read and misuse the information. This vulnerability often arises due to poor security configuration or failure to implement secure communication protocols.



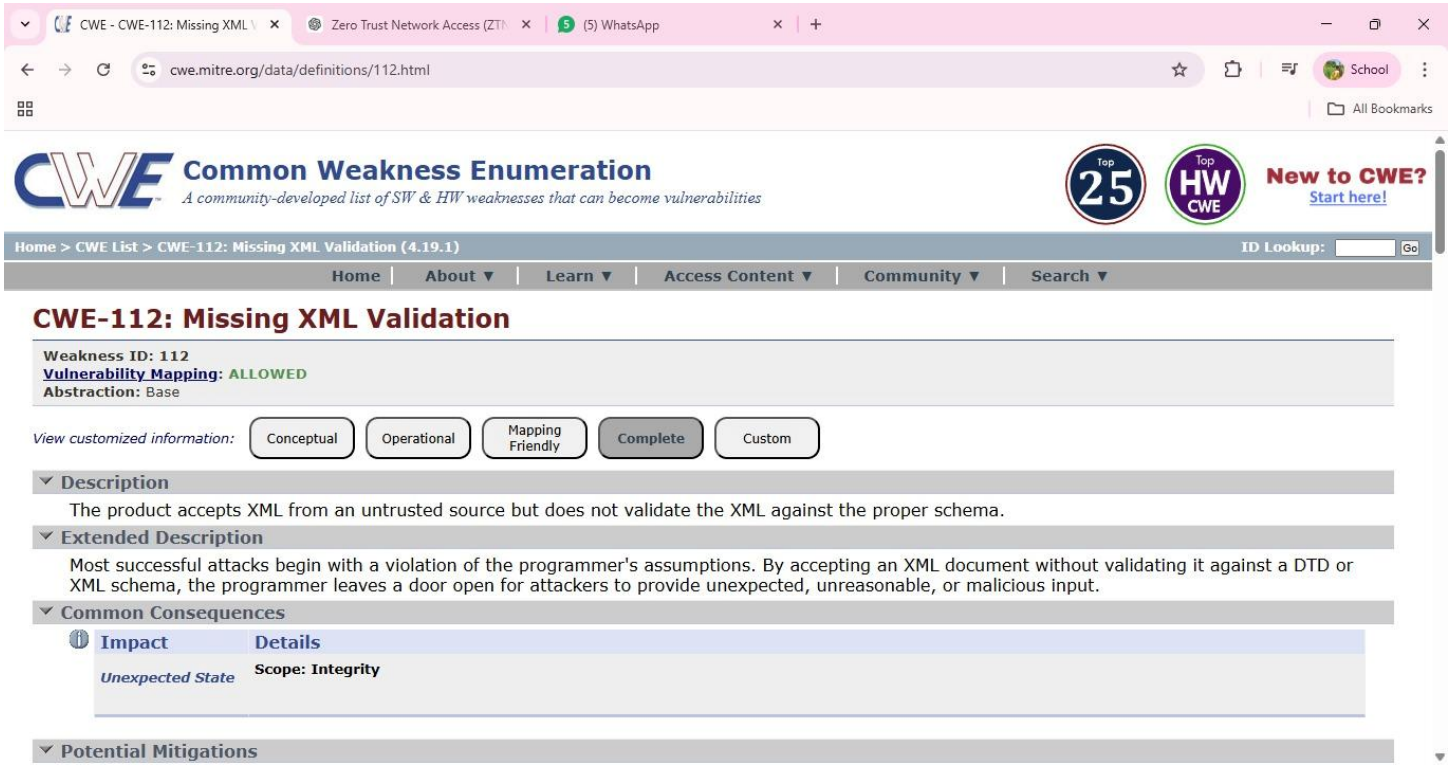
8) Vulnerability Name: **Missing XML Validation**

CWE/CVE: CWE-112

OWASP/SANS Category: A05 :2025-Injection

Description: Missing XML Validation occurs when an application processes XML input without properly validating its structure or content. XML is widely used for data exchange between systems, and if proper validation mechanisms are not implemented, attackers may send specially crafted XML data to manipulate application behavior. Without validation, the system may accept malicious or malformed XML input that can lead to security vulnerabilities such as XML injection, data manipulation, or unauthorized access to system resources.

Business Impact: If XML inputs are not properly validated, attackers may exploit this weakness to alter application data, bypass security checks, or disrupt normal system operations. This can lead to data integrity issues, service interruptions, and potential exposure of sensitive information.For organizations, such incidents may result in operational disruptions, financial losses, and reduced trust from customers or partners due to compromised system security.



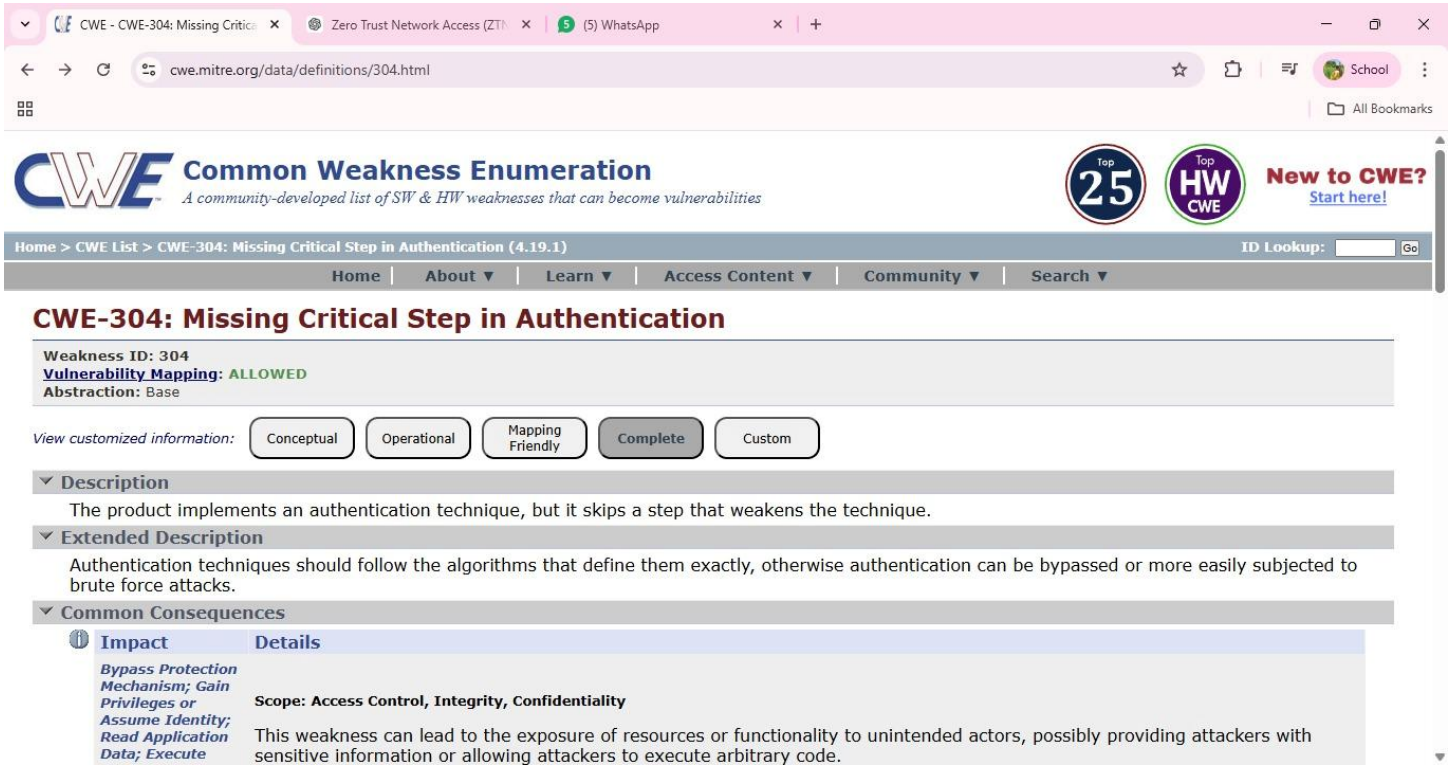
9) Vulnerability Name: Missing Critical Step in Authentication

CWE/CVE: CWE-304

OWASP/SANS Category: A07 :2025-Authentication Failures

Description: Missing Critical Step in Authentication occurs when an application fails to enforce an essential step in the authentication process required to verify a user's identity. This may happen when security mechanisms such as multi-factor authentication, verification tokens, or session validation are skipped or improperly implemented. As a result, attackers may bypass authentication controls and gain unauthorized access to protected resources or user accounts. Such vulnerabilities often arise due to poor authentication logic or incomplete implementation of security checks.

Business Impact: If critical authentication steps are missing, attackers may successfully bypass login protections and gain unauthorized access to sensitive systems or user accounts.This can lead to data breaches, unauthorized transactions, and compromise of confidential information. For organizations, the impact may include financial losses, legal consequences, and damage to their reputation due to the failure to properly protect user authentication processes.



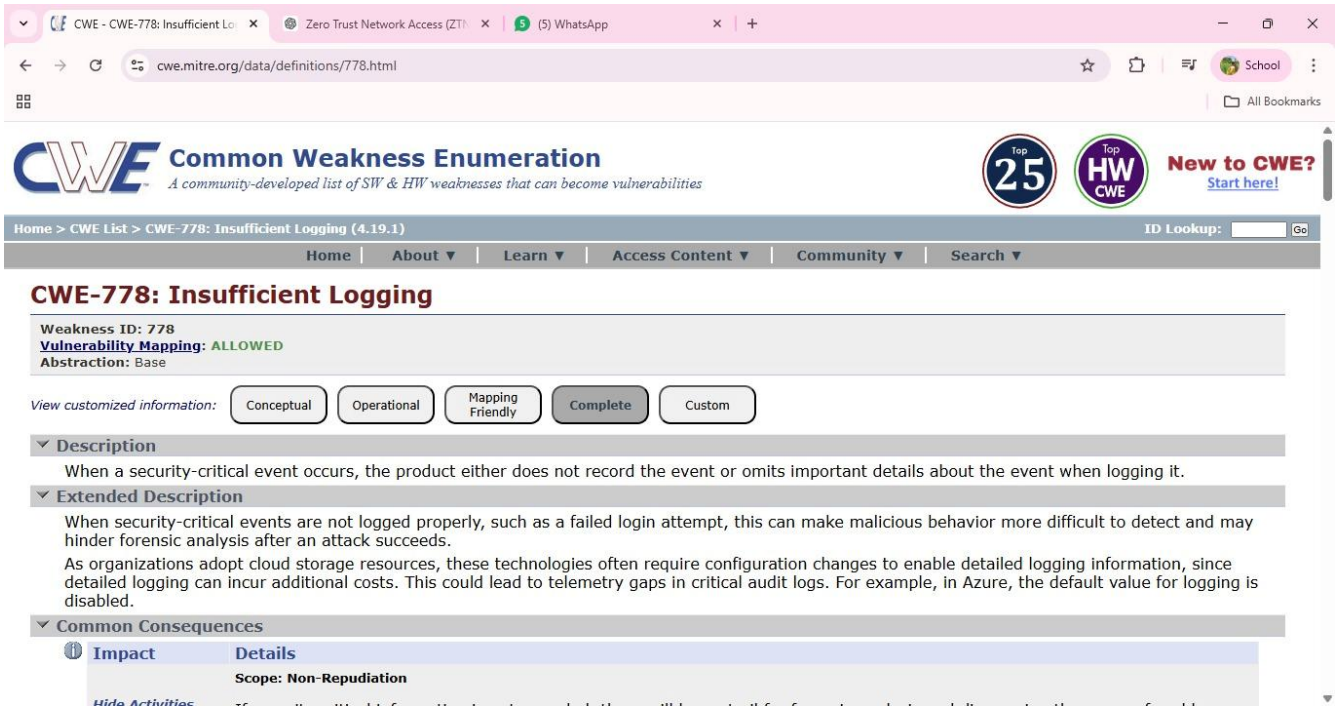
10) Vulnerability Name: Insufficient Logging

CWE/CVE: CWE-778

OWASP/SANS Category: A09 :2025-Security Logging and Alerting Failures

Description: Insufficient Logging occurs when an application or system fails to properly record security-related events such as login attempts, access requests, system errors, or configuration changes. Without adequate logging mechanisms, it becomes difficult to detect suspicious activities, unauthorized access attempts, or potential security breaches. Attackers may exploit this weakness to perform malicious actions without leaving sufficient evidence for administrators to identify or investigate the incident.

Business Impact: Lack of proper logging can significantly delay the detection of security incidents and make it difficult for organizations to respond effectively to cyber threats. Without accurate logs, identifying the source and impact of an attack becomes challenging, which may result in prolonged system compromise or data breaches. This can lead to operational disruptions, financial losses, regulatory compliance issues, and damage to the organization's reputation.



Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability

s.no	Vulnerability name	Severity	plugins
1	TCP/IP Timestamps Supported	INFO	25220
2	Service Detection	INFO	22964
3	SSL / TLS Versions Supported	INFO	56984
4	TLS Version 1.3 Protocol Detection	INFO	138330
5	Additional DNS Hostnames	INFO	46180
6	TLS ALPN Supported Protocol Enumeration	INFO	84821
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	OS Fingerprints Detected	INFO	209654
10	TLS Version 1.2 Protocol Detection	INFO	136318

REPORT: -

1. **Vulnerability Name : -** 25220 **- TCP/IP Timestamps Supported**
   Severity: INFO

   Plugin: - 25220

   Port: - N/A

Description: - The remote host supports TCP timestamps as defined in RFC1323. This feature is used to improve network performance and reliability by helping with round-trip time calculations and protection against wrapped sequence numbers. However, a side effect of TCP timestamps is that an attacker may be able to estimate the uptime of the remote system. By analyzing timestamp values in TCP packets, it may be possible to determine how long the system has been running since its last reboot.

Solution: -

If the exposure of system uptime information is a concern, administrators can disable TCP timestamps in the operating system's network configuration. This can typically be done by modifying system network settings or kernel parameters depending on the operating system in use. Disabling this feature may slightly affect certain TCP performance optimizations

Business Impact:

This issue does not directly compromise the system or expose sensitive data. However, it can reveal system uptime information, which may provide useful insights to attackers when performing reconnaissance on the network. Understanding system uptime could help attackers plan targeted attacks or identify systems that have not been recently restarted or updated. Proper configuration and monitoring can help minimize such information exposure**.**

2**. Vulnerability Name** : - Service Detection

Plugin: - 22964

Port: - 80 / tcp / www

Description: - The scan detected the service running on the remote host by analyzing the service banner or by examining the response returned when an HTTP request was sent. Banner information or error messages from services may reveal details about the software, web server, or application running on the target system. This information helps identify the type and version of services operating on the host.

Solution: - Administrators can reduce information exposure by configuring services to hide or limit banner information and detailed error messages. Web servers and applications should be configured to suppress version details and unnecessary system information. Regular updates and proper service configuration also help minimize unnecessary information disclosure**.**

Business Impact: - This issue does not directly pose a security threat. However, exposed service details can assist attackers during the reconnaissance phase by revealing information about the technologies used in the system. Such information may help attackers identify potential vulnerabilities associated with specific services or software versions. Proper configuration helps reduce this information exposure and strengthens overall security posture.

3. **Vulnerability Name : -** SSL / TLS Versions Supported

Severity: - INFO

Plugin: - 56984

Port: - 443 / tcp / www

Description: - The scan identified the Secure Sockets Layer (SSL) and Transport Layer Security (TLS) protocol versions supported by the remote service for encrypting communications. These protocols are used to secure data transmitted between the client and the server. Detecting supported SSL/TLS versions helps administrators understand which encryption protocols are enabled on the server and whether they meet current security standards.

Solution: - Administrators should review the enabled SSL/TLS versions on the server and ensure that only secure and up-to-date protocols are allowed. Older and insecure versions should be disabled to maintain strong encryption standards. Regularly updating the server configuration and security settings will help ensure that secure communication protocols are used.

Business Impact: - This information does not directly represent a vulnerability but reveals which encryption protocols the server supports. Attackers could use this information during reconnaissance to identify outdated or weak SSL/TLS versions if they are enabled. Ensuring that only modern and secure protocols are supported helps maintain strong protection for data transmitted over the network.

4. **Vulnerability Name: -** TLS Version 1.2 Protocol Detection

Severity: - INFO

Plugin: - 136318

Port: - 443 / tcp / www

Description: - The scan detected that the remote service supports Transport Layer Security (TLS) version 1.2 for encrypting communications. TLS 1.2 is a widely used cryptographic protocol that helps secure data transmitted between clients and servers over the internet. This detection simply confirms that the service can establish encrypted connections using TLS 1.2.

Solution: - Ensure that the server continues to support secure and up-to-date encryption protocols. Administrators should verify that insecure protocols such as older SSL or TLS versions are disabled if they are not required. Regular updates and proper configuration of SSL/TLS settings help maintain strong communication security.

Business Impact: - This finding is informational and does not indicate a direct vulnerability. The presence of TLS 1.2 support confirms that the server is capable of providing secure encrypted communication. Proper management of supported protocols ensures that data transmitted between users and the server remains protected from interception.

5. **Vulnerability Name: - 46180 - Additional DNS Hostnames**

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6. Vulnerability Name:-TLS ALPN Supported Protocol Enumeration

Severity: - INFO

Plugin: - 84821

Port: - 443 / tcp / www

Description: The scan detected that the remote host supports the Application-Layer Protocol Negotiation (ALPN) extension in TLS. ALPN allows the client and server to negotiate which application-layer protocol should be used during the TLS connection, such as HTTP/1.1 or HTTP/2. This plugin enumerates the protocols supported by the ALPN extension on the remote service.

Solution: - Administrators should review the protocols supported by the ALPN extension and ensure that only necessary and secure protocols are enabled. Disabling unused or outdated protocols can help reduce unnecessary information exposure and improve the security configuration of the server. Regular updates and proper server configuration are also recommended.

Business Impact: - This finding is informational and does not indicate a direct security risk. However, the disclosure of supported protocols may provide useful information to attackers during the reconnaissance phase. Understanding which protocols are enabled on a server could help attackers identify potential weaknesses if outdated or insecure protocols are present. Proper configuration and monitoring can help reduce this exposure.

7. **Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)**

   Severity: - INFO

   Plugin: - 45

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8. VulnerabilityName: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network

management, optimization, and ensures that the right security measures are in place for each device type.

9.Vulnerability Name: - OS Fingerprints Detected

Severity: - INFO

Plugin: - 209654

Port: - N/A

Description: - The scan detected operating system fingerprints from the remote host using multiple remote probing techniques such as TCP/IP, SMB, HTTP, NTP, and SNMP. These probes analyze how the system responds to network requests in order to identify characteristics of the underlying operating system. While the most accurate result is reported in the OS Identification plugin, this plugin lists all fingerprints that were detected during the scanning process.

Solution: - Administrators can reduce the exposure of system fingerprint information by limiting unnecessary network services and filtering external requests using firewalls or intrusion prevention systems. Proper network configuration and regular system updates can also help reduce information disclosure about the operating system.

Business Impact: - This finding is informational and does not represent a direct security vulnerability. However, information about the operating system can assist attackers during reconnaissance activities. Knowing the type of operating system may help attackers search for known vulnerabilities related to that system. Limiting unnecessary information exposure can improve the overall security posture of the network**.**

10.Vulnerability Name: - TLS Version 1.3 Protocol Detection

Severity: - INFO

Plugin: - 138330

Port: - 443 / tcp / www

Description: The scan detected that the remote service supports Transport Layer Security (TLS) version 1.3 for encrypting network communications. TLS 1.3 is the latest and more secure version of the TLS protocol, designed to provide stronger encryption, improved performance, and better protection against modern security threats. This detection confirms that the server is capable of establishing secure encrypted connections using TLS 1.3**.**

Solution: - Administrators should ensure that TLS 1.3 remains enabled and properly configured on the server. It is also recommended to disable older and less secure protocols such as SSL and outdated TLS versions if they are not required. Regular updates and proper configuration of encryption settings help maintain strong communication security.

Business Impact: - This finding is informational and does not represent a security vulnerability. Supporting TLS 1.3 is considered a good security practice because it provides stronger encryption and better protection for data transmitted over the network. Proper management of encryption protocols ensures secure communication between users and the server.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

- **Legacy VPN Architecture**

Legacy VPN architecture is a network security model that creates an encrypted tunnel between a remote user and an organization's internal network using on-premises hardware appliances like VPN concentrators . Unlike modern solutions, legacy VPNs operate on an "authenticate once, trust indefinitely" principle. Once a user successfully authenticates, they are placed directly onto the internal network with an IP address, effectively becoming a node on that network .

This architecture was designed for a different era when all users were in offices and all applications were in data centers. It relies on the concept of a "trusted internal network" versus an "untrusted external internet"—the castleand-moat model . The VPN concentrator acts as the drawbridge: once crossed, the user is trusted and granted broad access to internal resources based on their IP address rather than their identity .

- **Limitations of Legacy VPN**

Legacy VPN architectures present significant security and operational challenges in today's distributed work environment. The limitations include:

1. Over-permissioned Access: Once connected, users gain network-level access, meaning a compromised faculty laptop can scan, discover, and attack other systems on the internal network (lateral movement) . 2. Expanded Attack Surface: VPN concentrators must be exposed to the public internet with open ports (typically IPsec on UDP 500 or SSL VPN on TCP 443), making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation .
3. Poor User Experience: Traffic is often "hair-pinned"—routed from the user to the data center and then out to the internet for SaaS applications—causing latency and slow performance .
4. Scalability Challenges: Hardware VPN appliances have hard capacity limits. During peak times (e.g., start of semester), users face connection failures, requiring manual upgrades of expensive hardware .
5. Operational Overhead: IT staff must patch, upgrade, and maintain physical VPN appliances, applying firmware updates and managing certificates .

- **The Problem: Lateral Movement and Attack Surface**

The core security weaknesses of legacy VPNs are the expanded attack surface and the risk of lateral movement. Attack Surface: The VPN concentrator's publicly exposed IP address and open ports invite constant scanning and attacks. Threat actors use tools to identify VPN appliances and exploit known vulnerabilities (e.g., CVE2019-11510, a critical Pulse Secure VPN vulnerability). Each exposed port is a potential entry point .

Lateral Movement: Once an attacker gains access via a compromised credential or vulnerability, they inherit the user's network-level access. The internal network, traditionally flat, allows the attacker to move laterally. From a single compromised faculty laptop, they can:

- Scan for other vulnerable servers (e.g., databases, file shares)
- Perform ARP spoofing or pass-the-hash attacks
- Pivot to high-value targets like the student information system or research data repositories • Deploy ransomware across the network

- **Zero Trust Architecture**

Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated, authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely .

The core tenets of Zero Trust include:

1. Assume Breach: Design the network as if attackers are already present.
2. Verify Explicitly: Authenticate and authorize based on identity, device health, and context.
3. Least Privilege Access: Grant only the minimum access necessary to perform a job function.
4. Micro-segmentation: Isolate workloads and users from one another to prevent lateral movement.

- **Zscaler Zero Trust Solution**

Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1. Zscaler Private Access (ZPA): A ZTNA service that provides seamless, identity-based access to private applications without placing users on the network. It connects users to applications, not the network .

2. Zscaler Internet Access (ZIA): A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location .

Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

• How Zscaler Eliminates Attack Surface

Zscaler eliminates the attack surface by making the organization's applications completely invisible to the public internet.

This is achieved through:

1. No Inbound Ports: Zscaler ZPA uses Zscaler App Connectors—lightweight VMs deployed in the data center—that initiate *outbound* connections to the Zscaler cloud. No inbound firewall ports need to be opened for remote access .
2. Application Invisibility: To an external port scanner, the university's applications do not exist. There are no IP addresses to scan, no ports to probe, and no VPN concentrators to attack .

3. DNS Resolution: ZPA does not rely on public DNS to resolve internal application names. Applications are never exposed to the public DNS infrastructure .
4. Dark Cloud Principle: The Zscaler cloud acts as a broker. Users connect to the cloud, and the cloud connects to the application. The application server never sees the user's IP, and the user never sees the server's IP—only the application itself .

• How Zscaler Prevents Lateral Movement

Zscaler prevents lateral movement by ensuring users are connected to applications, not to the network.

The mechanisms include:

1. Application Segmentation: ZPA establishes a one-to-one, encrypted micro-tunnel between the user's device and the specific application they are authorized to access. The user never receives an IP address on the internal network .
2. No Network Visibility: Because the user is not placed on the network, they cannot scan, discover, or connect to other resources. There is no routing to adjacent systems. The network is invisible .
3. Identity-Based Micro-segmentation: Access policies are tied to user identity, not IP addresses. Even if an attacker compromises a user's credentials, they can only access the specific applications that user is authorized for—nothing else .

4. Continuous Monitoring: Zscaler monitors the connection throughout the session. If suspicious behavior is detected (e.g., impossible travel, anomalous data transfer), the connection can be terminated in realtime, preventing further movement .

• Zscaler Architecture Components

To understand how Zscaler replaces the legacy VPN, it is essential to understand its core components:

1. Zscaler Client Connector: A lightweight software client installed on user devices (laptops, desktops, mobile devices). It intelligently forwards traffic:
   - Private application traffic → ZPA for secure access
   - Internet-bound traffic → ZIA for security inspection
   - Bypassed traffic → Direct to internet (for performance)
2. Zscaler App Connector: A software component deployed as a VM in the university's data center or cloud environment. It initiates outbound connections to the Zscaler cloud and brokers connections to internal applications. Key features:
   - No inbound firewall rules required
   - Automatically scales horizontally based on load
   - Can be deployed in multiple locations for high availability
3. Zscaler Cloud: The global security platform that enforces policies, brokers connections, and inspects traffic. It consists of over 150 data centers worldwide, ensuring low-latency access .

4. **Zscaler Admin Portal: The centralized management console where administrators configure:**
   - Access policies
   - Application definitions
   - User and group mappings
   - Security settings
   - Integration Points

Zscaler integrates with existing university infrastructure to leverage current investments:

1. Identity Provider (IdP) Integration:
   - Azure AD / Okta: Zscaler integrates with the university's existing IdP for user authentication and MFA. This ensures consistent identity management and allows users to use their existing credentials .
   - SAML 2.0 / OpenID Connect: Supports modern authentication protocols for seamless single sign-on (SSO).

2. Endpoint Protection Integration:

- CrowdStrike / Microsoft Defender / Tanium: Zscaler checks device posture with integrated endpoint detection and response (EDR) tools. Access can be conditional on:
  - Antivirus running and up-to-date
  - Disk encryption enabled
  - OS patch level current
  - Device not jailbroken/rooted

3. SIEM/SOAR Integration:

- Splunk / Sentinel: Zscaler logs can be forwarded to the university's security information and event management (SIEM) system for centralized monitoring, alerting, and threat hunting .

4. Threat Intelligence Integration:

- MISP Integration: Zscaler can consume threat intelligence feeds from MISP to block access to known malicious domains, IPs, and URLs via ZIA .

- **MISP (Malware Information Sharing Platform) Integration**

MISP is an open-source threat intelligence platform that enables sharing of indicators of compromise (IOCs) within the security community. Integrating MISP with Zscaler enhances threat detection capabilities.

1. Threat Intelligence Ingestion:

- MISP aggregates IOCs from multiple sources—industry ISACs, open-source feeds, and internal threat research .
- These IOCs include malicious domains, IP addresses, URLs, and file hashes associated with known malware campaigns, phishing attacks, and command-and-control (C2) servers .

2. Integration Mechanism:

- The security team configures MISP to push threat intelligence feeds to the Zscaler cloud via API .
- Zscaler normalizes this data into its threat intelligence database .

3. Proactive Blocking:

- When a faculty member—even one authorized via ZPA—attempts to access a website that matches an IOC from the MISP feed, ZIA blocks the request .

4. Enhanced Threat Correlation:

- Security analysts can use MISP to cross-reference Zscaler logs. For example, if anomalous outbound traffic is detected from a compromised device, analysts can query MISP to determine if the destination IP is associated with a known threat actor .

- **Deployment Methodology**

Deploying Zscaler to replace the legacy VPN requires a structured, phased approach:

Phase 1: Discovery and Planning (Weeks 1-2)

1. Application Discovery: Catalog all internal applications currently accessed via VPN. This includes:
   - Student Information System (SIS) o ERP (Finance/HR)
   - o Library resources
   - Research computing clusters o Internal file servers
   - o Administrative portals
2. User Segmentation: Define user groups and their application access requirements: o Faculty: ERP, research servers, file shares o Students: Library resources, learning management system o Staff: Administrative portals, finance applications o IT Admins: Server management interfaces o External Collaborators: Specific research applications only
3. Traffic Analysis: Understand current traffic patterns to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy).

Phase 2: Infrastructure Deployment (Weeks 3-4)

1. Deploy App Connectors:
   - Provision App Connector VMs in the university data center (minimum 2 for high availability) o Configure them with outbound internet access to connect to Zscaler cloud o No inbound firewall rules required
2. Configure App Connector Groups:
   - Group connectors by function or location o Associate them with specific applications for traffic steering

3. Integrate Identity Provider:
   - Configure SAML 2.0 between Zscaler and Azure AD o Map user groups from Azure AD to Zscaler o Test authentication flow

Phase 3: Policy Configuration (Weeks 5-6)

1. Define Applications in ZPA: o Add each internal application (by IP, port, and protocol) o Associate applications with App Connector groups o Configure application segmentation

2. Create Access Policies:
   - Build granular policies based on user groups:
     - *"Faculty can access ERP on TCP 443 from devices with antivirus enabled after MFA"*
     - *"Researchers can access HPC Cluster on TCP 22 from managed devices only"*
     - *"External Collaborators can access Research Repository on TCP 443 between 9 AM-5 PM"* 3. Configure ZIA Policies:
   - Set up URL filtering o Enable threat protection (IPS/IDS)
   - Configure data loss prevention (DLP) rules for sensitive data

Phase 4: Pilot Deployment (Weeks 7-8)

1. Select Pilot Group: Choose a small group of willing faculty and IT staff (10-20 users).
2. Deploy Zscaler Client Connector: Provide installation instructions and assist with setup.
3. Monitor and Validate:
   - Verify authentication and MFA flows o Test application access o Validate that users cannot access unauthorized applications o Collect feedback on performance

4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12)

1. Phased Rollout: Deploy to user groups in waves:
    - Week 9: Faculty and researchers o Week 10: Administrative staff o Week 11: Students (if applicable) o Week 12: IT staff and remaining users
2. Communication and Training:
    - Send pre-deployment emails with instructions o Provide user guides for Zscaler Client Connector
    - o Establish support channels for issues
3. Legacy VPN Decommissioning:
    - Once all users are migrated, revoke legacy VPN access
    - o Shut down VPN concentrators
    - Remove public DNS records pointing to VPN

Phase 6: Optimization and Continuous Improvement (Ongoing)

1. Log Analysis: Regularly review Zscaler logs in the admin portal for anomalies.
2. Policy Refinement: Update policies based on changing user roles and application additions.
3. Threat Hunting: Use integrated threat intelligence (MISP) to proactively search for compromised accounts.

• Threat Intelligence in Zscaler Environment

Threat intelligence transforms Zscaler from an access control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk. Sources of Threat Intelligence:

1. Zscaler Cloud Logs: Real-time data on connections, including:
    - User identity and group membership
    - Source IP and geolocation o Destination application and IP o Bytes transferred and session duration o Device posture information
2. External Threat Feeds (MISP): Structured IOCs from trusted sources:
    - Known malicious domains (e.g.,

phishing sites) o Command-and-control server IPs o Ransomware distribution URLs o File hashes of malware samples

3. Identity Provider Logs: Authentication data from Azure AD:
   - Successful and failed login attempts of MFA status o Impossible travel anomalies

4. EDR Integration: Endpoint detection tools provide:
   - Compromised device alerts of Malware detections o Anomalous process behavior

Applications of Threat Intelligence:

1. Adaptive Access Control: o If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can:
   - Step-up authentication (require additional MFA)
   - Block access entirely ▪ Restrict to read-only access
2. Compromised Account Hunting: o Analysts query Zscaler logs to identify:
   - Users accessing applications at unusual hours
   - Unusual data transfer volumes (potential exfiltration)
   - Access from unusual geographic locations o Cross-reference with MISP to see if destination IPs are known malicious
3. Proactive Threat Blocking:
   - MISP feeds are pushed to ZIA for real-time enforcement o When any user attempts to access a blocked domain, the request is denied o Alerts are generated for security team investigation

• Incident Response in Zero Trust Model

Incident response is fundamentally improved in a Zscaler Zero Trust environment. The ability to instantly revoke access and the inherent lack of lateral movement transforms how security teams respond to threats. Incident Response Workflow:

1. Detection:
   - Alert Trigger: The SOC receives an alert from Zscaler logs or integrated EDR tool. Example: A faculty account is downloading 50GB of research data at 3:00 AM, far exceeding normal behavior.
   - Investigation Initiation: The analyst opens the Zscaler admin portal and views the session details:
     - User: Dr. Smith (Faculty_Research group)
     - o Device: Laptop "FAC-LT-342" (Windows 11, Defender active) o Application: Research Data Repository (SMB share)
     - Data transferred: 50GB in 15 minutes o Source IP: Unusual location (country different from user's normal location)

2. Containment:
   - Instant User Isolation: The analyst navigates to the user profile in the Zscaler portal and clicks "Deactivate User" or "Block Device." This action: o Terminates all active Zscaler connections immediately o Prevents any new authentication attempts o Takes effect globally within seconds (no firewall rules to update)
   - Impact of Containment: Because the user was never on the network, there is no lateral movement to contain. The attacker is limited to the single compromised application and cannot pivot.
3. Eradication:
   - The compromised device is remotely wiped or taken offline by IT helpdesk.
   - The user's password is reset in Azure AD.
   - The analyst checks MISP and Zscaler logs to determine how the account was compromised (e.g., phishing email received earlier that day).
   - The malicious domain from the phishing email is added to Zscaler's block list (or automatically ingested via MISP).
4. Recovery:
   - Once the device is clean (re-imaged or malware removed) and the password is reset, the analyst reenables the user in Zscaler.
   - The user authenticates with MFA from a clean device and regains access only to authorized

applications.

- All subsequent activity is closely monitored for 24-48 hours.

5. Post-Incident Review:

- The security team analyzes the incident to identify root cause and process improvements.
- Zscaler policies are updated: perhaps additional restrictions on sensitive research data (e.g., require approval for downloads over 1GB).

Benefits of ZTNA-Based Incident Response:

1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .
2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .
3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .
4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .
5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1. **Workload-to-Workload Segmentation:** Extend Zero Trust principles beyond user-toapplication connectivity to secure communication between internal workloads themselves. By deploying Zscaler Workload Segmentation, the university can enforce micro-segmentation within the data center and cloud environments, preventing lateral movement even between application tiers (e.g., web server to database server) without relying on network firewall rules.

2. **Branch and Campus Transformation:** Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.
3. **OT and IoT Security Integration:** Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.
4. **Advanced Data Loss Prevention (DLP):** Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.
5. **AI-Driven Threat Hunting:** Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).
6. **Privileged Remote Access for Vendors:** Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.
7. **Integration with SOAR Platforms:** Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For example, if Zscaler detects a compromised device, the SOAR platform can automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.

8. **Continuous Compliance Automation:** Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate least-privilege access, data protection controls, and audit readiness to regulators and internal auditors.
9. **Zero Trust for Mergers and Acquisitions:** As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access specific resources without being placed on the internal network, maintaining security during transitional periods.
10. **User Behavior Analytics (UBA):** Implement advanced user behavior analytics to detect insider threats and compromised accounts. By analyzing patterns of application access, data transfer volumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END